

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

Active exploitation of the Fortinet pre-auth RCE vulnerability

Date of Publication

December 13, 2022

Admiralty Code

A1

TA Number

TA2022294

Summary

First Seen: December 12, 2022

Affected Product: FortiOS

Impact: results in an unauthenticated attacker executing arbitrary code

CVE

CVE	NAME	PATCH
CVE-2022-42475	Remote code execution in FortiOS sslvpngd	

Vulnerability Details

Fortinet has addressed a critical security flaw in its FortiOS SSL-VPN product, which is being actively exploited in the wild. The heap-based buffer overflow bug in FortiOS sslvpngd is listed as CVE-2022-42475 and results from a boundary error in the sslvpngd daemon. When exploited maliciously, the issue might enable unauthenticated attackers to remotely crash devices and perhaps execute arbitrary code.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-42475	FortiOS: 7.2.0 - 7.2.2, 7.0.0 - 7.0.8, 6.4.0 - 6.4.10, 6.2.0 - 6.2.11	cpe:2.3:o:fortinet:fortios :-:*:*:*:*:*:*	CWE-122

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Link' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0040</u> Impact	<u>TA0001</u> Initial Access	<u>TA0004</u> Privilege Escalation
<u>T1548</u> Abuse Elevation Control Mechanism	<u>T1543</u> Create or Modify System Process	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities
<u>T1210</u> Exploitation of Remote Services	<u>T1584</u> Compromise Infrastructure	<u>T1565</u> Data Manipulation	<u>T1190</u> Exploit Public-Facing Application

Indicator of Compromise (IOCs)

TYPE	VALUE
File Path	/data/lib/libips.bak /data/lib/libgif.so /data/lib/libiptcp.so /data/lib/libipudp.so /data/lib/libjpeg.so /var/.sslvpnconfigbk /data/etc/wxd.conf /flash

TYPE	VALUE
IP Address: Ports	188.34.130.40:444 103.131.189.143:30080 103.131.189.143:30081 103.131.189.143:30443 103.131.189.143:20443 192.36.119.61:8443,444 192.36.119.61:444 172.247.168.153:8033

🔗 Patch Link

<https://www.fortiguard.com/psirt/FG-IR-22-398>

🔗 References

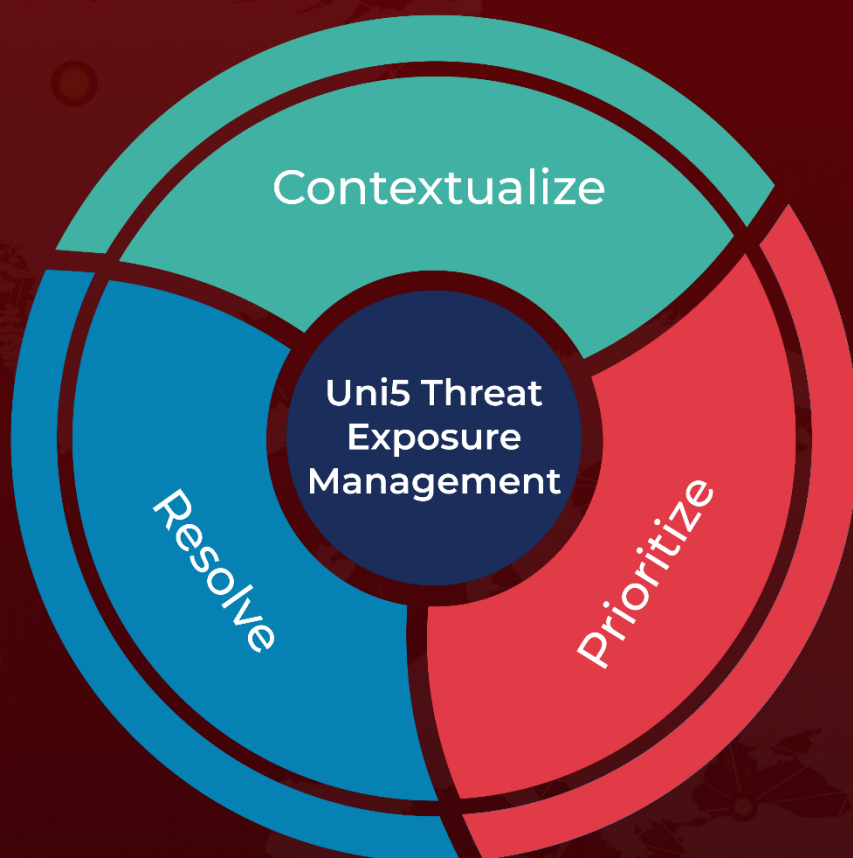
<https://thehackernews.com/2022/12/fortinet-warns-of-active-exploitation.html>

<https://www.fortiguard.com/psirt?date=12-2022&severity=5>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 13, 2022 • 12:24 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com